

420-D03-AB · CYBER DEFENSE · AEC CYBERSECURITY LEA.D8 · STUDENT SELF-STUDY EDITION

Introduction to the Course

and Defense Methods

01

Work through this deck on your own. Everything you need is on the slides — nothing is hidden in speaker notes.

Class 1 of 23 · 29 August 2026 · Competency EZ03 — To apply access control measures

Cyber.SoHo Educational Hub · content current to 11 August 2026

How to use this deck on your own

Allow about two hours, in two sittings

- Lesson 1 (slides 4–22) is roughly 35 minutes. Lesson 2 (slides 23–48) is roughly 70 minutes.

Do the six worked examples — they are the course, not decoration

- Each has a TASK statement, a diagram, runnable code, and a numbered walkthrough.
- Every script is in the artifact package. Run them; do not only read them.

Answer the checkpoint questions before looking at the answers

- Checkpoints are at slides 22 and 48. Answers are on the same slides, lower down. Cover them first.

Before you open ANY link in this deck

- Check it at <https://www.virustotal.com/gui/home/url> — this is a course requirement, not a suggestion.

What you must have done before Class 2 (Tuesday 1 September)

- The five homework items on slide 52, plus Lab 01's four deliverables on slide 51.

What today covers

Part	Section	Worked example
LESSON 1	Introduction to the Course	
1.1	The competency: EZ03 and its four elements	
1.2	The 2026 threat picture, in published numbers	
1.3	How this course is graded — the assessment chain	RLE-01 · Python · CPM scaffold
1.4	The toolchain: free, open-source, and one deliberate use of AI	RLE-02 · Python · local AI triage
1.5	The line you do not cross	
LESSON 2	Defense Methods	
2.1 – 2.2	Three definitions · the seven layers · three failure modes	
2.3 – 2.4	Finding the doors · zoning	RLE-03 · Bash · entry-point register
2.5	The control taxonomy	RLE-04 · PowerShell · defence baseline
2.6	Essential cyber hygiene and the three frameworks	RLE-05 · HTML · readiness console
2.7 – 2.9	Active defence · the SOC · measuring depth	RLE-06 · Python · residual risk

A teal-colored circle containing the white text 'L1' in a bold, sans-serif font.

L1

Introduction to the Course

What the course is for, what 2026 actually looks like, how you are graded, and where the legal line sits.

- 1.1 The competency: EZ03 and its four elements
- 1.2 The 2026 threat picture, in published numbers
- 1.3 How this course is graded — and the thing most students miss
- 1.4 The toolchain: free, open-source, and one deliberate use of AI
- 1.5 The line you do not cross

OPENING

A promise, and a warning.

PROMISE — by 24 October you can walk into a small business, look at their network, and tell them in writing, with evidence, where they can be attacked, what would stop it, and what it costs. That is not a lecture skill. That is the actual job.

WARNING — this course is 3-3-3: three hours lecture, three practical, three homework. Students who fail almost never fail the exam. They fail because they did the labs and never wrote them down.

1.1 One competency, four elements

EZ03 — To apply access control measures · covered completely

Element	In plain language
1. Apply cyberdefence techniques	Know where the network can be entered, put controls at those points, divide it into zones, run active defences, build in redundancy.
2. Control access to hosts	Know what each machine is for, control who logs in and with what rights, configure its firewall, harden it, then PROVE the hardening worked.
3. Control network access	Control identities across zones, configure the network firewall, deploy detection and prevention, secure wired and wireless protocols, then PROVE it.
4. Apply cryptography techniques	Understand the concepts, implement the main cryptosystems, know how they are attacked, choose the right one, protect data in transit and at rest.

Note how often 'prove' appears. Elements 2 and 3 both end with 'rigorous validation of the effectiveness of the access control measures applied.'

1.1 The definition you must memorise ⚠

Cyber defense — as defined by the course outline for this AEC

- All the techniques and actions that make an infrastructure defensible and ensure its cyber resilience.
- Cyber defense techniques include active defence techniques, perimeter security, defence in depth, and the redundancy elements that enable business continuity in the event of a cyber attack.

Where this course sits in the programme

- Before: 420-D01-AB Preventive Surveillance — you know how to WATCH a network.
- Now: 420-D03-AB Cyber Defense — you learn to CHANGE it.
- After: Cyber Threat and Risk Analysis → Conformity Assessment → Vulnerability Management → Intrusion Testing → Cybersecurity Incident Management → Business Cybersecurity Management.

Why that order matters

- In Intrusion Testing, students attack the kind of configuration you build here. In Incident Management, you clean up after configurations that were built badly. This is the course where you decide which of those two experiences you would rather be having.

1.2 The 2026 threat picture, in three numbers

31%

of breaches now start with exploitation of a vulnerability — up from 20%, now the TOP initial access vector

48%

of breaches involved a third party — a 60% increase in one year

43

days: the median time to patch, worsened from 32. Attackers now measure exploitation in hours.

*Source: Verizon Data Breach Investigations Report 2026 (19th edition) — 31,000+ incidents, 22,000+ confirmed breaches, 145 countries.
[verizon.com/business/resources/reports/dbir/](https://www.verizon.com/business/resources/reports/dbir/)*

1.2 The full picture — and what each finding changes for you

2026 DBIR finding	Number	What it changes
Vulnerability exploitation — top initial access vector	31%	Patching is a defence layer, not an IT chore. LAB_03.
Credential abuse as a single vector	13%	Identity still spans full attack chains. LAB_02.
Human element involved	62%	Awareness and process are layer 1. The Manual.
Breaches involving a third party	48%	Assume vendor connections are hostile. LAB_01.
System Intrusion — top breach pattern since 2022	60%	Detection is not optional. LAB_04.
Median time to patch	43 days	Your patch SLA is a control you can measure.
Median ransomware payment / refusal rate	\$139,875 / 69%	Refusal is only possible with tested backups.
Unapproved 'shadow AI' use by employees	45%	Use AI deliberately and locally, not accidentally.
Mobile social engineering success	up 40%	The perimeter includes a phone in a pocket.

Read the last three rows together: attackers got faster through automation, defenders got slower because there is more to patch, and staff are pasting data into unapproved tools.

1.2 Vocabulary change: MITRE ATT&CK v19 ⚠

- ATT&CK = Adversarial Tactics, Techniques, and Common Knowledge (The MITRE Corporation)
- v19 released 28 April 2026 · v19.1 released 12 May 2026 · attack.mitre.org

The change that affects your reports

- 'Defense Evasion' has been RETIRED as a tactic and split into two:
- Stealth (TA0005) — the attacker hides inside normal behaviour (obfuscation, process injection, indicator removal)
- Defense Impairment (TA0112) — the attacker actively switches your protections off

Why the split matters to a defender

- The countermeasures differ. You detect stealth by knowing what normal looks like.
- You detect impairment by alerting when a security control stops reporting.
- Two different alert rules, and two different owners.
- A 2024 article saying 'Defense Evasion' is not wrong. It is old. Use the v19 names in your lab reports.

1.3 How this course is graded

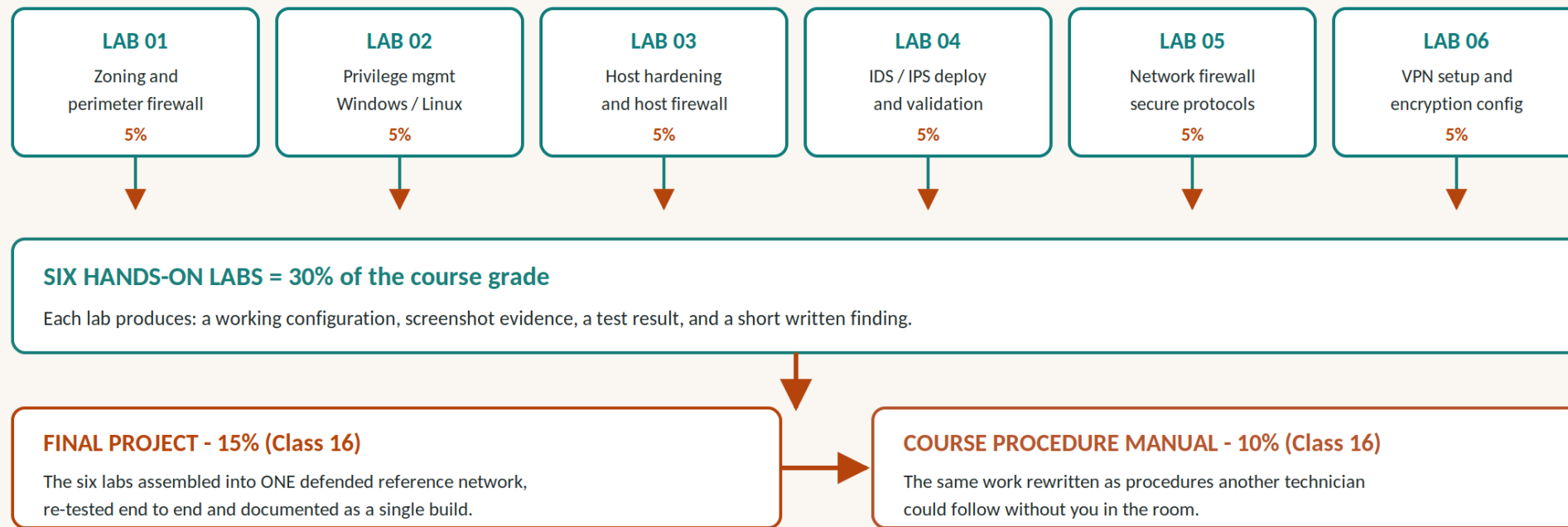
Evaluation	Weight	When	Elements	Final eval
Hands-on labs — 6 × 5%	30%	Classes 2, 4, 6, 8, 12, 17	EZ03 1–4	
Quizzes — 4 × 2.5%	10%	Classes 2, 9, 14, 18	EZ03 1–4	
Mid-Term Exam	10%	Class 10 · 22 September	EZ03 1–3	✓
Final Project	15%	Class 16 · 7 October	EZ03 1–4	✓
Course Procedure Manual	10%	Class 16 · 7 October	EZ03 1–4	✓
Final Exam	25%	Class 23 · 24 October	EZ03 1–4	✓
TOTAL	100%	Course runs 29 Aug → 24 Oct 2026		60%

1.3 The one thing most students miss

30% + 15% + 10% = 55% of your grade is ONE continuous body of work

FIG-01 The Assessment Chain of 420-D03-AB

One body of work, graded three times: 30% + 15% + 10% = 55% of the final mark



Nothing here is thrown away. Every screenshot you take in Week 1 is evidence you will submit in Week 8.

FIG-01 — Six labs at 5% become the Final Project at 15%, which becomes the Course Procedure Manual at 10%.

1.3 How the chain works — and the one rule that decides your term

1. Each lab (5%) produces exactly four things

- A working configuration · screenshot evidence · a test result proving the control functions · a short written finding.

2. The Final Project (15%) is not a new build

- It is the six labs assembled into ONE coherent defended network, re-tested end to end. If your six labs contradict each other — and they will, if built carelessly — this is where it shows.

3. The Course Procedure Manual (10%) is the same work again, as procedures

- Not a description of what you did. Instructions a different technician could follow, in a different room, without you, to reproduce your result.

THE RULE: write the lab up the same evening you do it.

- About forty minutes per lab, and you finish the term calmly. Skip it and you spend the first week of October trying to remember what a screenshot from 12 September was supposed to prove.

Seven mandatory sections per lab

- Objective · Scope and assumptions · Pre-conditions · Procedure · Verification · Rollback · Evidence

RLE-01 — 'The Monday you inherit a network'

Python · `rle01_cpm_scaffold.py` · ▶ run this tonight

TASK THIS EXAMPLE PERFORMS

- Build the folder structure, document skeleton and evidence register a technician needs on day one of taking responsibility for a network they did not build — which is also, precisely, your Course Procedure Manual.

HOW IT RELATES TO THE LECTURE

- Section 1.3 claimed documentation is a defensive control rather than overhead. This makes it concrete: run the script tonight, and the folder it creates is where every lab gets written down.

THE SITUATION

- A managed-service provider in Saint-Laurent takes on a new client: a fourteen-person accounting firm. The previous IT contractor retired in June and left a business card and a password on a sticky note.
- Nobody at the firm can say how many servers there are. The new technician has one week to produce something the partners will sign. She does not start with tools. She starts with a structure.
- Because the first question the insurer asks after any incident is 'show me your documentation', and the second is 'when was it last updated?'

RLE-01 · What the script produces on disk

TASK: Generate the CPM folder tree, cover page, six lab templates and the evidence register

```
CPM_Firstname_Lastname/
├── 00_COVER.md           <- cover page + document-control version table
├── README.md            <- the five rules for keeping the manual alive
├── EVIDENCE_REGISTER.csv <- one row per screenshot, with WHAT IT PROVES
├── LAB_01/
│   ├── LAB_01.md         <- 7 pre-built sections matching the marking grid
│   └── evidence/         <- screenshots named EV-001_*.png
├── LAB_02/ ... LAB_06/

# Evidence register columns - the critical one is what_it_proves:
#   BAD : "Firewall screenshot"           -> earns nothing
#   GOOD: "WAN interface blocks inbound TCP 3389 after" -> a claim tied
#           rule 4 was applied"           to evidence

$ python3 rle01_cpm_scaffold.py --student "Firstname Lastname"
[OK] Course Procedure Manual skeleton created at: ./CPM_Firstname_Lastname
[OK] 6 lab folders, 7 sections each, 1 evidence register.
[!] Next step: open 00_COVER.md and put your student number on it.
```

- The hash_sha256 column lets you prove a screenshot has not been altered since capture — forensic reasoning.
- Three mistakes to avoid: a synced cloud folder edited on two machines · writing a password into the manual · waiting until October.

RLE-01 · The seven sections are the marking grid, in code

TASK: Hard-code the graded structure so a student cannot accidentally omit a section

```
# Define the seven sections every lab write-up must contain. This is the
# marking grid turned into a template, so a student cannot forget a graded element.
SECTIONS = [
    ("1. Objective",          "...which competency element (EZ03.1-4) it satisfies."),
    ("2. Scope and assumptions", "Exact hosts, IP ranges, VLANs, versions. And what it does NOT cover."),
    ("3. Pre-conditions",      "Snapshots taken, credentials available, change window agreed."),
    ("4. Procedure",           "Numbered steps. One action per step."),
    ("5. Verification",        "The test that PROVES the control works, plus expected result."),
    ("6. Rollback",            "How to put the system back if the change breaks production."),
    ("7. Evidence",            "Screenshot names, command output, date/time captured."),
]

def safe_folder_name(name):
    # Replace anything that is not a letter, digit, dash or underscore, because
    # spaces and accented characters break shell commands later in the term.
    cleaned = "".join(ch if ch.isalnum() or ch in "-_" else "_" for ch in name)
    # Collapse repeated underscores so "Jean  Pierre" does not become "Jean__Pierre".
    while "__" in cleaned:
        cleaned = cleaned.replace("__", "_")
    return cleaned.strip("_")
```

- pathlib creates LAB_0n/evidence/ in one call with parents=True, and exist_ok=True means re-running never crashes.
- The if __name__ == "__main__" guard lets a later lab import these functions without the generator firing.

1.4 The toolchain — every tool is free, and that is deliberate

Layer	Tools	Official sites
Perimeter	pfSense CE · OPNsense · WireGuard	pfsense.org · opnsense.org · wireguard.com
Network	Suricata · Zeek · Security Onion · Wireshark · Sigma	suricata.io · zeek.org · securityonion.net · wireshark.org · sigma-hq.io
Host	Wazuh · Lynis · OpenSCAP · Greenbone / OpenVAS	wazuh.com · cisofy.com/lynis · open-scap.org · greenbone.net
Data	OpenSSL · step-ca (Smallstep)	openssl.org · smallstep.com
Validation	Atomic Red Team · MITRE Caldera	atomicredteam.io · caldera.mitre.org
Local AI	Ollama · Open WebUI · Hugging Face	ollama.com · openwebui.com · huggingface.co
Safety	VirusTotal — check every link before opening it	virustotal.com/gui/home/url

The model drafts. The analyst decides. The analyst's name goes on the record.

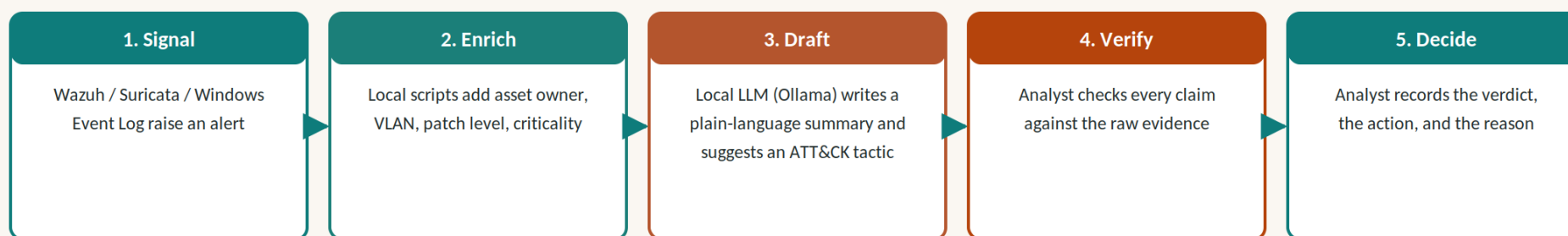
1. RUN IT LOCALLY — Ollama at 127.0.0.1. No log extract, no client name, no configuration file leaves the building. A security log names hosts, accounts, internal addresses and often the exact vulnerability that is currently unpatched: it is a reconnaissance report about your own client.
2. TREAT EVERY OUTPUT AS A DRAFT — a model produces fluent, confident, plausible summaries it partly invented. That is not a bug you can prompt away. If you cannot point at the raw evidence yourself, it does not go in your report.
3. DECLARE IT — tool, model, and what you changed after checking. Undeclared AI text is an academic-integrity matter. Declared and verified use is encouraged: that is the professional norm now.

1.4 Where a local model is allowed to help

Human-in-the-loop AI triage

FIG-06 Human-in-the-Loop AI Triage - Where a Local Model Is Allowed to Help

The model drafts. The analyst decides. Every decision is logged with the analyst's name, not the model's.



THREE RULES THAT APPLY EVERY TIME YOU USE AI IN THIS COURSE

1. The model runs locally. No client data, no log extract, and no configuration file leaves your machine.
2. Output is a draft, never a verdict. If you cannot point at the evidence yourself, you do not submit it.
3. You declare it. Every lab report names the tool, the model, and what you changed after checking.

Why this matters in 2026: the Verizon DBIR reported unapproved 'shadow AI' use inside organisations tripled to 45%, and the same report flagged AI-assisted attacks compressing exploit timelines from months to hours.

FIG-06 — Stages 1–3 can be automated. Stages 4 and 5 cannot, and any vendor telling you otherwise is selling something.

RLE-02 — 'The 02:14 alert nobody can read'

TASK: strip what must never leave, draft a summary locally, write an auditable record a human must sign

Pattern stripped BEFORE the model sees anything	Example in the sample alert	Replaced with
Email address	helene.tremblay@example-firm.ca	<EMAIL_REDACTED>
Phone number	514-555-0142	<PHONE_REDACTED>
password= / passwd= / secret= / api_key= / token=	password=Sup3rSecret!2026	password=<SECRET_REDACTED>
Hexadecimal string of 40+ characters	a3f5c9d21b7e4408af6621b9cd0e7742aa19bf3c	<LONG_HEX_REDACTED>

RLE-02 · Naming is a control

TASK: Send only redacted text to a LOCAL model, and store its output under a name that cannot be misread

```
# Point at the loopback address only. 127.0.0.1 is not routable - packets sent
# to it never touch a network card. That is what makes this defensible at all.
OLLAMA_URL = "http://127.0.0.1:11434/api/generate"
DEFAULT_MODEL = "llama3.2:3b"    # small enough for a laptop with no GPU

# The back-reference \1 KEEPS the key name and destroys only the value.
# Knowing a secret leaked into a ticket is useful; knowing the secret is a liability.
(re.compile(r"(?i)\b(password|passwd|secret|api[_]?key|token)\b\s*[:=]\s*\S+"),
 r"\1=<SECRET_REDACTED>"),

record = {
    "assistant": model_used,          # exact model name, for reproducibility
    "draft_not_verdict": draft,       # <- the model output. Read the key name.
    "analyst_name": "",               # empty ON PURPOSE - structurally
    "analyst_verdict": "",            # incomplete until a person types in it
    "policy": "AI output is advisory. No record is closed until analyst_name
              and analyst_verdict are filled in by a person.",
}
```

- Constraining a model is mostly naming the failure you expect: 'Do not invent host names, users, IP addresses or times.'
- ► Run BOTH: --offline (no model, no GPU, no network) and with the model. The offline version is duller and never wrong; the model version is easier to read and about 1 time in 10 asserts something the alert does not support. Finding that one time is the actual skill.

1.5 The line you do not cross ⚠

Everything you learn here is dual-use.

- The knowledge that lets you find an exposed service is the knowledge that lets someone else exploit it. The difference is not skill. It is AUTHORISATION.

Authorisation means four things, all of them

- WRITTEN permission · from someone with the AUTHORITY to grant it · covering SPECIFIC systems · in a SPECIFIC window

The law

- Canada — Criminal Code s.342.1 (unauthorised use of a computer); s.430(1.1) (mischief re computer data)
- United States — CFAA, 18 U.S.C. §1030 · EU — Directive 2013/40/EU · Spain — Ley Orgánica 10/1995
- Quebec — Law 25 governs personal information you encounter, including accidentally

In this course, and in your first job

- Your own lab environment. Never the College network. Never an employer without a signed scope. Never a friend's business 'as a favour' — the favour is what the Crown calls the offence.
- When you find something serious: stop, document, report to a named person in writing, let them decide. Do not 'just check one more thing.' That sentence has ended careers.



Videos for Lesson 1 — and the conditions of use

PRIMARY — watch before Class 2

- What Is a Security Operations Center (SOC)? | SOC Explained | SOC for Beginners — under 15 minutes
- <https://www.youtube.com/watch?v=nf2Gn4K8erM>

SUPPLEMENTARY

- Overview — NIST Cybersecurity Framework 2.0 <https://www.youtube.com/watch?v=f-6J7-WqcGE>
- Learn Ollama in 15 Minutes — Run LLM Models Locally for FREE <https://www.youtube.com/watch?v=UtSSMs6ObqY>

CONDITIONS OF USE — read before pressing play

- Cyber.SoHo Educational Hub does not own, host, mirror, reproduce, transcribe or distribute any of this material, and claims no affiliation with, sponsorship by, or endorsement from any channel, creator or platform named. Each link was reachable on 11 August 2026.
- DO watch on the original platform, at the original link, where the creator receives the view.
- DO NOT download, re-upload, embed in a submitted assignment, or paste transcripts into your Manual.
- Cite a video the way you would cite a book: creator, title, platform, date accessed. Check every link at [virustotal.com/gui/home/url](https://www.virustotal.com/gui/home/url) first.

Checkpoint — end of Lesson 1 (cover the answers first)

QUESTIONS

- 1. What single competency does this course cover, and what are its four elements?
- 2. What percentage of your grade comes from labs + Final Project + Manual combined?
- 3. According to the 2026 DBIR, what is now the top initial access vector, and at what percentage?
- 4. State the AI rule for this course in one sentence.
- 5. What makes an activity authorised rather than criminal?

ANSWERS

- 1. EZ03 — apply cyberdefence techniques; control access to hosts; control network access; apply cryptography.
- 2. 55% (30% labs + 15% Final Project + 10% Course Procedure Manual).
- 3. Exploitation of a vulnerability, 31% — up from 20%, overtaking credential abuse at 13%.
- 4. The model drafts, the analyst decides, and the analyst's name goes on the record.
- 5. Written permission, from someone with authority, for specific systems, in a specific window.

L2

Defense Methods

What defence precisely means, the seven layers you will build, and how professionals classify and measure them.

- 2.1 Three definitions · 2.2 The seven layers and three failure modes
- 2.3 Finding the doors · 2.4 Zoning
- 2.5 The control taxonomy · 2.6 Essential cyber hygiene and the frameworks
- 2.7 Active defence — and what it is not · 2.8 The SOC
- 2.9 Measuring depth: why the second layer beats the best layer

2.1 Three definitions you must state exactly ⚠

DEFENCE IN DEPTH

- Placing multiple INDEPENDENT controls along the same attack path, so that the failure of any one control does not result in compromise.
- The essential word is independent. Two products from the same vendor, relying on the same signature feed, running on the same host, are ONE control wearing two names.

DEFENSIBLE ARCHITECTURE

- A network whose design makes defence possible: boundaries you can name, traffic that must pass through inspection points, systems whose role is known, and logs that leave the machine that produced them.
- A flat network is not 'insecure' — it is UNDEFENDABLE, which is worse, because no amount of budget fixes it without redesign.

CYBER RESILIENCE

- The ability of the organisation to keep delivering its service WHILE an attack is under way and AFTER it succeeds.
- Not prevention. Tested backups, documented procedures, spare capacity, and a named person who knows what to do in the first thirty minutes.

2.2 The seven layers

An attacker must defeat EVERY layer. You only need ONE layer to hold.

FIG-02 Defence in Depth: Seven Layers, Seven Independent Chances to Stop an Attack		
Read top to bottom. An attacker must defeat every layer; a defender only needs one layer to hold.		
LAYER	TYPICAL CONTROLS YOU WILL BUILD IN THIS COURSE	WHAT FAILURE LOOKS LIKE IN THE REAL WORLD
1. Governance and People Layer 1 of 7	Policies, security awareness, joiner-mover-leaver process, MFA enrolment rules	Staff member approves an MFA push they did not request
2. Physical Layer 2 of 7	Locked racks, badge access, cable management, disposal of old drives	Server room propped open during a delivery
3. Perimeter Layer 3 of 7	Edge firewall, published-service list, VPN gateway, DDoS filtering	Remote Desktop published to the internet on port 3389
4. Network Layer 4 of 7	VLAN zoning, internal segmentation, IDS/IPS, DNS filtering, 802.1X	Flat network: one compromised laptop reaches the accounting server
5. Host Layer 5 of 7	Host firewall, EDR, patching, secure baseline, disabled legacy protocols	Unpatched server 43 days after the vendor released the fix
6. Application and Identity Layer 6 of 7	Least privilege, input validation, MFA, service-account hygiene, secrets management	Domain admin account used for daily email
7. Data and Recovery Layer 7 of 7	Encryption at rest and in transit, offline backup, restore testing, DLP	Backups exist but nobody has ever tested a restore

FIG-02 — Each layer, the controls you build in this course, and what failure looks like in the field.

2.2 The seven layers — and where each is graded

#	Layer	Controls you build in this course	Graded in
1	Governance and People	Policies, awareness, joiner-mover-leaver process, who may approve access	Manual s.2, s.7
2	Physical	Locked racks, badge access, secure disposal, cable discipline	LAB_01 (as an assumption)
3	Perimeter	Edge firewall, published-service list, VPN gateway	LAB_01, LAB_06
4	Network	VLAN zoning, internal segmentation, IDS/IPS, DNS filtering, wireless separation	LAB_01, 04, 05
5	Host	Host firewall, endpoint protection, patching, hardening baseline	LAB_02, LAB_03
6	Application and Identity	Least privilege, MFA, service-account hygiene, secrets management	LAB_02
7	Data and Recovery	Encryption at rest and in transit, offline backup, tested restore	LAB_06, Project

On layer 2: you will not install door locks in this course. You will DOCUMENT physical assumptions. A written assumption that turns out false is a finding; an unwritten one is a disaster.

2.2 Three failure modes of layered defence ⚠

1. CORRELATED FAILURE — this is the one the exam asks about

- Two 'independent' layers share a dependency: the same credential, the same certificate authority, the same management console.
- A stolen domain-administrator account defeats layers 4, 5, 6 and 7 in a single step.
- Design question to ask yourself: what single fact, if false, breaks more than one of my layers?
- Examples: one admin credential · a management VLAN reachable from the user zone · one hypervisor hosting the firewall, the file server AND the backup · every product from one vendor with one update channel.

2. THE UNMONITORED LAYER

- A control that blocks silently and reports nothing is half a control: prevention with no intelligence. Every layer must produce a signal that leaves the host.

3. DEPTH WITHOUT BREADTH

- Seven layers on the front door and none on the side entrance. This is exactly why section 2.3 exists.

2.2 One attack path, seven places to break it

Attacker sequence on top (MITRE ATT&CK v19 tactics) · your next eight weeks underneath

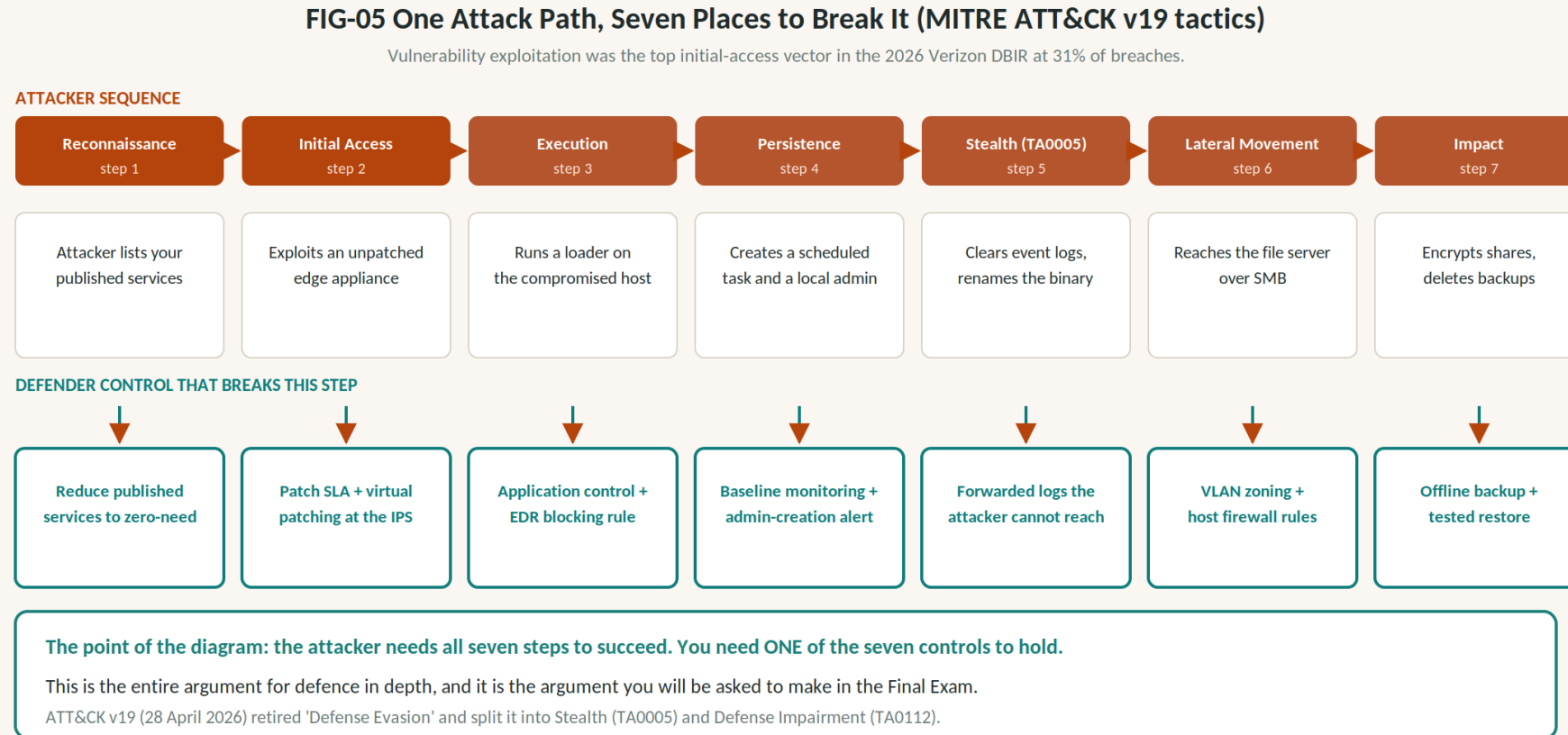


FIG-05 — The control under Stealth is not a product. It is 'forwarded logs the attacker cannot reach.' Some of your strongest controls cost nothing but a design decision.

2.3 Finding the doors — the four categories of entry point

Attack surface = the geography · Entry point = one door · Attack vector = how the door gets opened

Category	Examples	Why it gets missed
Deliberate and known	VPN gateway, web server, mail flow	Rarely missed — also rarely reviewed after the day it was built
Deliberate and forgotten	A firewall rule opened for a 2023 project; a vendor's remote-support tool	Nobody removed it because nobody owned it
Accidental	A service bound to 0.0.0.0 instead of 127.0.0.1; a test system with a public address	Default configuration, never audited
Not recognised as computers	Printers, cameras, smart TVs, building controls, badge readers	Nobody on staff thinks of them as attack surface

2.3 Eight entry points in a fourteen-person office

Four external paths, plus four device classes nobody counts

FIG-03 Entry-Point Schematic: 14-Person Accounting Firm, Montreal

Every arrow that crosses the dashed line is a perimeter element you must be able to name.

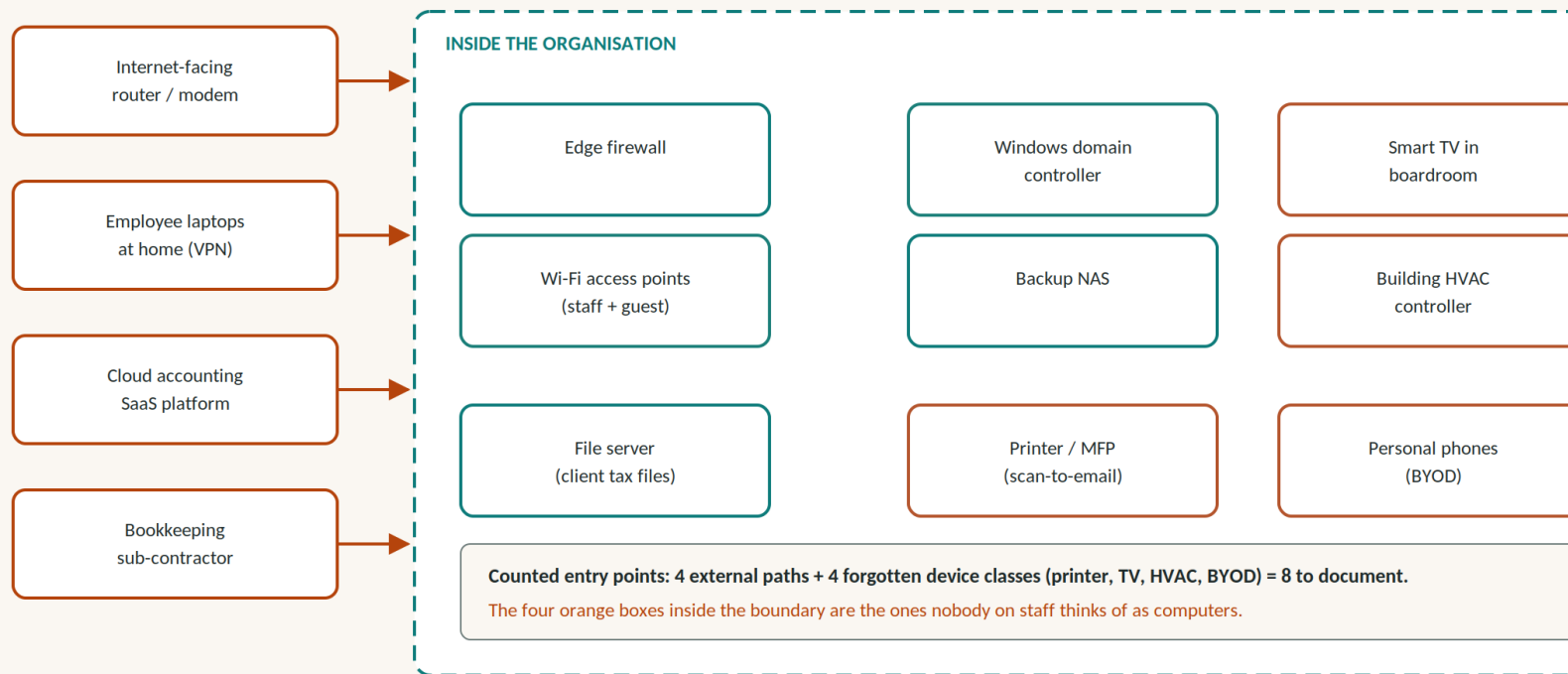


FIG-03 — The heating controller was installed by the landlord and talks to a vendor cloud service nobody in the firm has heard of. That is the 48% third-party statistic made physical.

RLE-03 — 'Counting the doors before buying locks'

TASK: list every service THIS host offers, classify its exposure, write the register to CSV — touching nothing else

Bind address	Classification	What it means	Action
0.0.0.0 · :: · *	ALL_INTERFACES	Reachable from every network the host is attached to	Justify it in writing, or bind it to loopback
127.0.0.1 · ::1	LOOPBACK_ONLY	Reachable only from the machine itself	Lowest exposure — no action
a specific address	SPECIFIC_INTERFACE	Reachable on one network only	Confirm that network is the intended zone

RLE-03 · Bash parameter expansion, and why 0.0.0.0 matters

TASK: Read local listening sockets, classify exposure, and record a decision — not a score

```
# Split the address from the port at the LAST colon, which is IPv6-safe.
# ${LOCAL%:*} removes the shortest match of :* from the END -> the address
# ${LOCAL##*:} removes the longest match of *: from the START -> the port
# These are parameter expansions, not commands - no subprocess is spawned.
ADDR="${LOCAL%:*}"
PORT="${LOCAL##*:}"

# 0.0.0.0 is not an address - it is a wildcard meaning EVERY interface on this
# host. A database bound to 0.0.0.0 is reachable from the guest wireless network.
# The same database bound to 127.0.0.1 is reachable only by local processes.
if [[ "${ADDR}" == "0.0.0.0" || "${ADDR}" == "*" || "${ADDR}" == "[::]" ]]; then
    EXPOSURE="ALL_INTERFACES"
    RISK="Reachable from the network. Justify it or bind it to 127.0.0.1."
elif [[ "${ADDR}" == "127.0.0.1" || "${ADDR}" == "[::1]" ]]; then
    EXPOSURE="LOOPBACK_ONLY"; RISK="Local only. Lowest exposure. No action needed."
else
    EXPOSURE="SPECIFIC_INTERFACE"
    RISK="Reachable on one interface. Confirm that interface is the intended zone."
fi
```

- set -uo pipefail: without pipefail, 'ss | tail' reports success even when ss was not installed — and you file a register saying 'no services' about a machine running twelve.
- ► Try it: run the script, then run `python3 -m http.server 8080`, then run it again. Watch your own action become a documented entry point.

2.4 Zoning — the design you build in LAB_01

A zone = systems sharing a trust level, separated by a control point that INSPECTS traffic between them

Zone	Contains	Rule of thumb
Perimeter / edge	The firewall itself, VPN termination	Nothing else lives here
Servers	File server, domain controller, backup target	Accepts from Users. Initiates almost nothing outbound
Users	Staff workstations and laptops	Reaches Servers on named ports only. Cannot reach unmanaged devices
Unmanaged / IoT	Printers, cameras, TV, building controls	Internet if it must. Nothing internal
Guest	Client and visitor devices	Internet only. Complete isolation from every other zone
Management	Switch, firewall, hypervisor admin interfaces	Reachable from a named admin workstation only

2.4 Three rules for writing zone rules — you are graded on these

1. DEFAULT DENY

- The last rule in every ruleset denies everything, and logs it. Every allowed flow is then an exception you can name and justify.

2. NAME THE FLOW, NOT THE ADDRESS

- 'Users → Servers, TCP 445, file sharing' survives an IP address change.
- '10.64.20.0/24 → 10.64.30.10 allow' does not, and nobody in two years will know why it exists.

3. LOG THE DENIES YOU CARE ABOUT

- Logging every denied packet fills the disk. Logging denied traffic BETWEEN INTERNAL ZONES tells you something has gone wrong inside — which is exactly the signal you want.

Think it through: guest and staff wireless share one VLAN. Name two bad outcomes.

- (1) A client's malware-infected laptop can reach the file server.
- (2) The guest password, written on a card in reception, now grants access to the staff network.
- Both are real, both are common, and both are fixed by one VLAN and three rules in LAB_01.

2.5 The control taxonomy — how professionals classify what they build

Every control has one FUNCTION (what it does about the attack) and one TYPE (how it is implemented)

FIG-04 Control Taxonomy Grid - Say It the Way an Auditor Says It

Every control you deploy has one FUNCTION (what it does about the attack) and one TYPE (how it is implemented).

	Administrative (written / procedural)	Technical (configured in a system)	Physical (built or installed)
Preventive	Access-control policy; signed acceptable-use	Firewall deny rule; MFA enforcement	Door lock on the server room
Detective	Quarterly access review; log review procedure	IDS signature; file-integrity monitor	Motion sensor; security camera
Corrective	Incident-response plan; disciplinary process	Automatic host isolation; patch deployment	Fire suppression; replacement hardware
Deterrent	Published sanctions; login warning banner	Account lockout after failed attempts	Visible camera; fencing and lighting
Compensating	Two-person rule when MFA cannot be used	Jump host in front of a system too old to patch	Locked cabinet for a device with no password

FIG-04 — Five functions across three types. Practise until you can place any control instantly: 'login warning banner' = deterrent, administrative.

2.5 Two observations that separate strong students from average ones

FIRST — most real controls are technical and preventive. Most real GAPS are administrative and detective.

- Organisations buy products. They do not write procedures and they do not check their logs.
- When you assess a small business, that is where the findings are. Almost every time.

SECOND — compensating controls are where the profession actually lives.

- In a textbook you patch the system. In reality the system runs a machine-tool controller from 2011 whose vendor no longer exists, and patching voids a warranty and stops production.
- So you compensate: isolate it in its own zone, put a jump host in front, allow exactly one source address, monitor every connection — and WRITE DOWN WHY.
- A compensating control that is not documented is indistinguishable from negligence.

Practice question: a client cannot enable MFA on an old accounting application. Give one compensating control.

- Acceptable answers: restrict the app to a VLAN reachable only from managed workstations · require VPN plus MFA to reach that VLAN · alert on any logon outside business hours · shorten the session timeout.
- Any of these is acceptable IF it is written down with the reason.

RLE-04 — 'The baseline you can show a client'

PowerShell · READ-ONLY · changes nothing, ever · `rle04_Get-DefenseBaseline.ps1`

#	Check	Layer	Why it earns its place
1	All three firewall profiles enabled	5 Host	A disabled Public profile is the one that matters in a café
2	Default inbound action = Block	5 Host	'Enabled' with an allow-all default is decoration
3	Real-time antimalware enabled	5 Host	Stops the file before it executes, not after
4	Signature age ≤ 3 days	5 Host	Yesterday's signatures miss today's loader
5	SMBv1 disabled	4 Network	The 2017 WannaCry / NotPetya protocol; still present on real networks
6	RDP listener state	3 Perimeter	Enabled is not automatically wrong — UNDOCUMENTED is
7	RDP Network Level Authentication required	3 Perimeter	Forces authentication before a session is created
8	Local administrator count ≤ 2	6 Identity	Every extra local admin is another credential worth stealing
9	System drive encrypted	7 Data	A stolen laptop is a data breach or an inconvenience — this decides which
10	Days since last update ≤ 30	5 Host	The 2026 DBIR median was 43 days. Beat the median.

RLE-04 · Three statuses, not two

TASK: Read ten Windows settings, compare each to the course baseline, score it, and export the evidence

```
# A typed .NET list, not a PowerShell array. Appending to an array with += rebuilds
# the WHOLE array every time - invisible with ten items, painful with ten thousand.
$Findings = New-Object System.Collections.Generic.List[object]

# Every check produces an object with the SAME five properties. Uniform shape is
# what makes Format-Table align and Export-Csv produce a clean file.
function Add-Finding {
    param([string]$Control,[string]$Observed,[string]$Expected,[string]$Status,[string]$Layer)
    $Findings.Add([pscustomobject]@{
        Control = $Control; Layer = $Layer; Observed = $Observed
        Expected = $Expected; Status = $Status          # PASS / FAIL / REVIEW
    })
}

# Every check is wrapped in try/catch. On a machine where BitLocker is unavailable
# or the user is not an administrator, the cmdlet throws. Without the catch, the
# script dies at check three and you never learn about checks four to ten.
try { $profiles = Get-NetFirewallProfile -ErrorAction Stop
    $enabled = ($profiles | Where-Object { $_.Enabled -eq $true }).Count
    $status = if ($enabled -eq 3) { "PASS" } else { "FAIL" } }
catch { Add-Finding "Firewall profiles" "could not read" "3 of 3" "REVIEW" "5 - Host" }
```

- PASS = measured and correct · FAIL = measured and wrong · REVIEW = a human must decide. Encoding 'it depends' into a script is a mature engineering choice.
- `$(Obj.Property)` — the subexpression operator. Without `$( )`, a double-quoted string prints the literal text `'.Property'`. The most common PowerShell error in student submissions.

2.6 Essential cyber hygiene — the small list that stops most attacks

cisecurity.org/controls/cis-controls-list · v8.1 aligned to NIST CSF 2.0 including the new Govern function

- CIS Critical Security Controls v8.1 — 18 controls, 153 safeguards, 3 Implementation Groups. IG1 = essential cyber hygiene, the set a small organisation with no dedicated security staff implements first.

The IG1 ideas that matter most here, in implementation order

- 1. Know what you have — inventory of devices and of software (Controls 1, 2). Everything else is guesswork without it.
- 2. Control who is an administrator — separate admin from daily accounts (Controls 5, 6)
- 3. Configure securely — change defaults, disable the unused, apply a documented baseline (Control 4)
- 4. Patch on a schedule you can state (Control 7)
- 5. Collect logs, OFF the host that produced them (Control 8)
- 6. Protect the boundary and segment the network (Controls 12, 13)
- 7. Back up, and TEST the restore (Control 11)
- 8. Train the people (Control 14)
- None of those eight requires buying a product. Every one requires a decision, a configuration and a written record.

2.6 The frameworks, and how they relate ⚠️

Framework	Published by	What it is for	Site
NIST CSF 2.0	NIST (United States)	Organising and communicating a programme: Govern, Identify, Protect, Detect, Respond, Recover	nist.gov/cyberframework
CIS Controls v8.1	Center for Internet Security	WHAT TO DO FIRST — prioritised safeguards; IG1 for small organisations	cisecurity.org/controls
MITRE ATT&CK v19	The MITRE Corporation	HOW ADVERSARIES BEHAVE — a shared vocabulary of tactics and techniques	attack.mitre.org
NIST SP 800-207	NIST	Zero Trust: being inside the network is not evidence of being authorised	csrc.nist.gov
Baseline Controls for SMOs	Canadian Centre for Cyber Security	Canadian guidance sized for small and medium organisations	cyber.gc.ca

RLE-05 — 'The readiness console'

Self-contained HTML · no CDN, no server, no framework · [rle05_defence_readiness_console.html](#) · ▶ run it tonight

TASK — turn the seven layers and the hygiene safeguards into one scored self-assessment that works offline

THE SITUATION

- A community organisation in Verdun: eleven staff, no IT budget, asks for 'a security check'. A full assessment would cost more than their annual technology spend. So: forty minutes, fourteen questions, one screen.
- The score is 39%. That number is not the deliverable — the four rows that scored zero are, in priority order, with the first costing nothing to fix.

SCORING — and why 'Unknown' scores zero

- Yes, and tested = 2 · Yes, not tested = 1 · No = 0 · Unknown = 0
- From an attacker's point of view there is no difference between a control that does not exist and a control nobody can confirm exists. Scoring them the same is not pessimism. It is accuracy.

WHY A SINGLE OFFLINE HTML FILE, NOT A WEB APPLICATION

- The answers describe exactly where their defences are weak. That document must not be uploaded anywhere. One file, runs from a USB stick, stores nothing, exports a CSV the client keeps.
- The most secure architecture is often the one with the fewest moving parts.

RLE-05 · The export that never touches a network

TASK: Score fourteen questions live, then hand the user a CSV built entirely inside the browser

```
/* Recalculate from scratch every time. Keeping a running total would be faster
   and would drift out of sync the first time an answer is changed twice. */
function updateScore(){
  var got = 0, answered = 0;
  for (var k in ANSWERS){
    // hasOwnProperty: without it, inherited prototype properties are counted,
    // producing a score that is subtly wrong in a way nobody notices for months.
    if (!ANSWERS.hasOwnProperty(k)) continue;
    answered++;
    // radix 10 is mandatory; || 0 turns the "0u" code for Unknown into zero.
    got += parseInt(ANSWERS[k],10) || 0;
  }
  var pct = Math.round((got / (ROWS.length * 2)) * 100);
  // Show the DENOMINATOR too. '39%' hides that only 6 of 14 were answered.
  document.getElementById("scoreLabel").textContent =
    answered + " of " + ROWS.length + " answered \u00b7 " + got + " of " + max + " points";
}
// Blob + createObjectURL build the file in the browser's own memory and hand the
// user a download. No server, no upload, no network request. That is what makes
// the "nothing leaves this machine" claim TRUE rather than merely stated.
var blob = new Blob([lines.join("\n")], {type:"text/csv;charset=utf-8"});
```

- Unanswered rows export an EMPTY score, not a zero. Blank = not assessed. Zero = assessed and absent. Conflating them overstates certainty, which is the most damaging thing a security report can do.
- The file uses overflow: clip on the expanding cards, embeds the logo as base64, and references no external stylesheet or script. If it needs the internet to render, it is not a document you can hand a client during an outage.

2.7 Active defence — and what it is NOT ⚠

ACTIVE DEFENCE IS

- Deliberate action to detect, disrupt, delay and study an adversary INSIDE systems you own or are authorised to operate.
- Intrusion prevention (IPS) — blocks traffic matching a known attack pattern in real time · LAB_04
- Automated isolation — removes a host from the network on a high-confidence detection · LAB_04
- Canary / honey tokens — a fake credential or file nobody legitimate should touch; any access is an alert
- Rate limiting and tarpitting — slows an attacker down, buying detection time · LAB_05
- Adversary emulation — Atomic Red Team, MITRE Caldera, in your OWN lab, to prove detections fire · LAB_04

ACTIVE DEFENCE IS NOT 'HACKING BACK'

- Accessing, disrupting or retaliating against a system you do not own is a criminal offence in Canada under Criminal Code s.342.1, regardless of what that system did to you first.
- It is also a terrible idea: attribution is usually wrong, the machine attacking you is usually another victim, and you will have destroyed the evidence your own insurer needs.
- Honeypots and canary tokens ARE legal on your own network — they are detective controls. They must sit inside your boundary and must not entice or gather information about a third party's systems.

2.8 Where all of this ends up — the Security Operations Centre

Four verbs: monitor, triage, investigate, respond. Built from people, process and technology — in that order.

Term	Expansion	What it does
SIEM	Security Information and Event Management	Collects logs from everywhere, correlates them, raises alerts
EDR	Endpoint Detection and Response	Agent on the host: detects behaviour, can isolate the machine
NDR	Network Detection and Response	The same idea applied to network traffic
XDR	Extended Detection and Response	A vendor term for combining the above under one console
SOAR	Security Orchestration, Automation and Response	Runs the repeatable parts of the response automatically
IDS / IPS	Intrusion Detection / Prevention System	Detects, or detects and blocks, known attack patterns
MDR	Managed Detection and Response	A SOC you rent instead of build — how most small organisations get one

2.9 Why the second layer beats the best layer ⚠

31.50%

FLAT — default perimeter firewall (30%) + signature antivirus (55%). Two layers.

10.00%

SINGLE STRONG — one excellent next-generation firewall at 90%, and nothing else.
One layer.

0.49%

DEFENDED — the seven ordinary layers this course builds, each 40–70%.

attack survives everything = $(1-p_1) \times (1-p_2) \times \dots \times (1-p_7)$ — the probabilities MULTIPLY, they do not add. 'Single strong' holds the best individual control in the model and still leaves about twenty times more residual risk than seven ordinary, cheap layers.

2.9 The arithmetic, layer by layer

Live in the workbook, sheet 'Layer Risk Model': change any blue percentage and every number below it recalculates

#	Defence layer	Stops alone	Survives before	Survives after	Removed here
1	Perimeter firewall with a published-service list	40.0%	100.00%	60.00%	40.00%
2	Network zoning (VLAN separation)	45.0%	60.00%	33.00%	27.00%
3	IDS / IPS at the zone boundary	50.0%	33.00%	16.50%	16.50%
4	Host hardening and host firewall	45.0%	16.50%	9.08%	7.43%
5	Endpoint detection and response	60.0%	9.08%	3.63%	5.44%
6	Least privilege and MFA on admin accounts	55.0%	3.63%	1.63%	2.00%
7	Offline, tested backup	70.0%	1.63%	0.49%	1.14%

THE TRAP: layer 7 removes barely one point, so students conclude later layers are not worth building. Wrong. Layer 7 is the layer that still works AFTER layers 1–6 have failed — which is the only day that matters.

RLE-06 · The honesty clause, printed on every run

TASK: Compute cumulative residual risk, compare three architectures, and state the model's own assumption

```
def residual_risk(layers):
    # Start at 1.0, meaning 'the attack gets through' before any layer is applied.
    survives = 1.0
    for _name, stop_probability, _why in layers:
        # The chance of surviving THIS layer is one minus its stop probability.
        # Note: this MULTIPLIES. Students frequently expect the percentages to add.
        survives *= (1.0 - stop_probability)
    return survives

# The depth-advantage ratio is COMPUTED, not typed. Never hard-code a number you
# can derive - it will eventually contradict the data printed next to it.
strong_risk = residual_risk(SCENARIOS["single_strong"]) * 100
deep_risk    = residual_risk(SCENARIOS["defended"]) * 100
print(f"...leaves {strong_risk/deep_risk:.0f} times more residual risk...")

# CONCLUSION 2 is printed on EVERY run, because the output is what gets pasted
# into a report. Building the caveat into the tool is more reliable than
# building it into the analyst's memory.
# "this model assumes the layers fail independently. They do not. A single
# stolen domain-administrator credential can defeat several layers at once."
```

- Each layer carries a JUSTIFICATION string as the third tuple element — you cannot add a layer without writing down why you chose that probability.
- ► Try it: change the backup layer from 0.70 to 0.00 and watch residual risk move from 0.49% to 1.63%. That is the conversation that sells a backup test instead of an appliance upgrade.



Videos for Lesson 2 — and the conditions of use

PRIMARY — watch before attempting Lab 01

- Defense in Depth in 7 Minutes | Security+ Must-Know — seven minutes
- <https://www.youtube.com/watch?v=yvBC1GYTHpc>

SUPPLEMENTARY — for the framework vocabulary in section 2.6

- NIST CSF 2.0 : Understanding in 5 minutes <https://www.youtube.com/watch?v=eVaeNHL8fRg>

CONDITIONS OF USE

- Cyber.SoHo Educational Hub does not own, host, mirror, reproduce, transcribe or distribute any of this material, and claims no affiliation with, sponsorship by, or endorsement from any channel, creator or platform named. Each link was reachable on 11 August 2026 and may change or be removed without notice.
- Watch on the original platform where the creator receives the view. Do not download, re-upload, embed in a submitted assignment, or paste transcripts into your Course Procedure Manual.
- Check every link at <https://www.virustotal.com/gui/home/url> before opening it. This is not a formality — it is the performance criterion 'consideration of relevant sources of information' applied to your own browsing.

Checkpoint — end of Lesson 2 (cover the answers first)

- 1. State the difference between defence in depth, defensible architecture, and cyber resilience.
- 2. Name the seven layers in order and give one control for each.
- 3. What are the four categories of entry point, and which is most often missed?
- 4. Classify 'a login warning banner' by function and by type.
- 5. What does a compensating control compensate for, and what must always accompany it?
- 6. Define active defence, and state one thing it explicitly excludes.
- 7. What do MTTD and MTTR measure, and why does MTTD matter even when prevention exists?
- 8. Why does a stack of seven 45% controls beat one 90% control?

ANSWERS

- 1. Independent controls on one path · a design that makes defence possible · continuing to deliver during and after. 2. Governance/People, Physical, Perimeter, Network, Host, Application/Identity, Data/Recovery.
- 3. Deliberate-known, deliberate-forgotten, accidental, not-recognised-as-computers — the last is most missed. 4. Deterrent, administrative. 5. An intended control that cannot be used; written justification.
- 6. Detect/disrupt/delay/study inside systems you own; it excludes hacking back. 7. Time to detect and time to respond — detection converts a breach into an incident. 8. Survival probabilities multiply, they do not add.

LAB 01 brief — due Class 2, Tuesday 1 September 2026

Weight 5% · Competency elements EZ03 1.1, 1.2, 1.3 · Quiz 01 the same evening

#	Deliverable	Where it comes from today
1	Entry-point register for your lab environment, minimum eight rows, with an owner and a business reason for each	RLE-03 script + 'Entry Point Register' sheet of the workbook
2	Zone design diagram naming at least five zones and the control point between them	Section 2.4 table (slide 35)
3	Perimeter ruleset with default-deny last, and every allow rule justified in one sentence	Section 2.4, three rules (slide 36)
4	Verification test proving one specific flow is blocked, with a screenshot and an evidence-register row	RLE-01 evidence register

These four map exactly to the four things every lab produces: a working configuration, evidence, a test result, and a written finding. The pattern repeats six times.

Homework — thirty minutes tonight, graded through Lab 01

1. ▶ Run `rle01_cpm_scaffold.py` with your own name.

– Open `00_COVER.md` and add your student number. This folder is your Manual for the whole term.

2. ▶ Run `rle03_entry_point_inventory.sh` on your lab virtual machine.

– Save the CSV into `LAB_01/evidence/` and add a row to `EVIDENCE_REGISTER.csv` describing what it proves.

3. ▶ Open `rle05_defence_readiness_console.html` and answer all fourteen questions honestly — for YOUR OWN home network.

– Export the CSV and keep it. You re-run this at Class 9 and Class 17, and the trend is part of your Final Project.

4. Watch the two primary videos (slides 23 and 50).

5. Optional but recommended: install Ollama (ollama.com) and pull a small model.

– `ollama pull llama3.2:3b` — then RLE-02 runs with a real model instead of the offline fallback.

Next class: Tuesday 1 September, evening. Zoning concepts • Quiz 01 • Lab 01 due.

Link index 1 of 2 — standards, frameworks and government bodies

Link	What it is	Why you need it
nist.gov/cyberframework	NIST Cybersecurity Framework 2.0	The six functions used to structure every report this term
csrc.nist.gov — SP 800-207	NIST Zero Trust Architecture	The authoritative definition of Zero Trust, free to download
cisecurity.org/controls/cis-controls-list	The 18 CIS Critical Security Controls	The prioritised list of what to do first; IG1 is essential hygiene
attack.mitre.org	MITRE ATT&CK	Adversary vocabulary; v19 split Defense Evasion into Stealth and Defense Impairment
cyber.gc.ca	Canadian Centre for Cyber Security	Canadian guidance, including baseline controls for small organisations
laws-lois.justice.gc.ca/eng/acts/c-46/	Criminal Code of Canada	Section 342.1 — the legal boundary of this course
cai.gouv.qc.ca	Commission d'accès à l'information du Québec	Quebec's privacy regulator; governs personal information you encounter
verizon.com/business/resources/reports/dbir/	Verizon Data Breach Investigations Report	The source of every statistic quoted in section 1.2

Link index 2 of 2 — tools, AI tooling and verification

Link	Tool	Layer / use
pfsense.org · opnsense.org	pfSense CE · OPNsense	3 Perimeter — edge and inter-zone firewall
suricata.io · zeek.org · securityonion.net	Suricata · Zeek · Security Onion	4 Network — detection, prevention, traffic analysis
wazuh.com · cisofy.com/lynis · open-scap.org	Wazuh · Lynis · OpenSCAP	5 Host — agent, hardening audit, benchmark scanning
greenbone.net	Greenbone / OpenVAS	5 Host — vulnerability scanning of your own lab hosts
wireguard.com · openssl.org · smallstep.com	WireGuard · OpenSSL · step-ca	3 and 7 — VPN, keys, certificates, your own small CA
wireshark.org · sigmahq.io	Wireshark · Sigma	4 Network — proving encryption; vendor-neutral detection rules
atomicredteam.io · caldera.mitre.org	Atomic Red Team · MITRE Caldera	Validation — proving detections fire, in your own lab only
misp-project.org	MISP	4 Network — threat-intelligence sharing
ollama.com · openwebui.com · huggingface.co	Ollama · Open WebUI · Hugging Face	AI — open-weight models running entirely on your own machine
virustotal.com/gui/home/url	VirusTotal	Required before opening any external link in this course



Abbreviations 1 of 2

Abbr.	Expansion	Abbr.	Expansion
AEC	Attestation d'études collégiales	IG1/2/3	Implementation Group 1 / 2 / 3 (CIS)
ATT&CK	Adversarial Tactics, Techniques, and Common Knowledge	IoT	Internet of Things
BYOD	Bring Your Own Device	IP	Internet Protocol
CIS	Center for Internet Security	IPsec	Internet Protocol Security
CSF	Cybersecurity Framework (NIST)	JSON	JavaScript Object Notation
CSV	Comma-Separated Values	LLM	Large Language Model
DBIR	Data Breach Investigations Report (Verizon)	MDR	Managed Detection and Response
DDoS	Distributed Denial of Service	MFA	Multi-Factor Authentication
DLP	Data Loss Prevention	MFP	Multi-Function Printer
DNS	Domain Name System	MSP	Managed Service Provider
EDR	Endpoint Detection and Response	MTTD	Mean Time To Detect
HTML	HyperText Markup Language	MTTR	Mean Time To Respond (or Recover)
HTTP/HTTPS	HyperText Transfer Protocol / HTTP Secure	NAS	Network Attached Storage
HVAC	Heating, Ventilation and Air Conditioning	NDR	Network Detection and Response
IDS / IPS	Intrusion Detection / Prevention System	NIST	National Institute of Standards and Technology



Abbreviations 2 of 2

Abbr.	Expansion	Abbr.	Expansion
NLA	Network Level Authentication	SMB	Server Message Block
PKI	Public Key Infrastructure	SMO	Small and Medium Organization
RAM	Random Access Memory	SOAR	Security Orchestration, Automation and Response
RDP	Remote Desktop Protocol	SOC	Security Operations Centre
SaaS	Software as a Service	SSH	Secure Shell
SIEM	Security Information and Event Management	SSL / TLS	Secure Sockets Layer / Transport Layer Security
SLA	Service Level Agreement	TCP / UDP	Transmission Control Protocol / User Datagram Protocol
GPU	Graphics Processing Unit	UTC	Coordinated Universal Time
ISO	International Organization for Standardization	VLAN	Virtual Local Area Network
CFAA	Computer Fraud and Abuse Act (United States)	VPN	Virtual Private Network
CPM	Course Procedure Manual	XDR	Extended Detection and Response

Disclaimer and Conditions of Use — 1 of 3

1. OWNERSHIP AND INTELLECTUAL PROPERTY

- All original content in this deck and its accompanying files — lecture text, the six real-life examples, the six figures, the Python, PowerShell, Bash and HTML source code, the spreadsheet templates and the structure of instruction — is the intellectual property of Cyber.SoHo Educational Hub, protected by the Copyright Act (R.S.C., 1985, c. C-42) of Canada and by international convention. © 2026. All rights reserved.
- Enrolled students may use, run, modify and reproduce these materials for their own study and for the assessed work of this course only. Any other reproduction, redistribution, publication, resale, incorporation into another course or product, or use to train, fine-tune or evaluate a machine-learning system, requires prior written permission from Cyber.SoHo Educational Hub.

2. NO AFFILIATION, NO ENDORSEMENT, THIRD-PARTY TRADEMARKS

- Cyber.SoHo Educational Hub is an independent educational brand. It is not affiliated with, sponsored by, endorsed by, accredited by or acting on behalf of any company, product, project, standards body, government agency, publisher, platform or educational institution named or linked anywhere in this material.
- All product, brand and project names and trademarks are the property of their respective owners and are used solely for identification, description, commentary, education and nominative fair use. Descriptions of standards are the author's own summary for teaching purposes — not authorised reproductions, not endorsed, and not a substitute for the original publications.

Disclaimer and Conditions of Use — 2 of 3

3. EXTERNAL LINKS AND VERIFICATION

- Cyber.SoHo does not control, host, monitor or guarantee any external site, file, video or service. You are required to verify any external link or downloaded file with a service such as [virustotal.com](https://www.virustotal.com) before opening or executing it. A clean result is an indicator, not a guarantee.

4. EDUCATIONAL PURPOSE, NO PROFESSIONAL ADVICE, NO WARRANTY

- For education only. Not professional, legal, regulatory, compliance, financial, insurance or security-consulting advice; not a certification, audit, penetration test or compliance attestation. All content is provided AS IS without warranty of any kind. Information accurate on 11 August 2026 may be outdated when you read it — re-verify statistics, versions and thresholds against their primary sources.

5. LAWFUL AND AUTHORISED USE ONLY

- Use every technique exclusively on systems you own or for which you hold explicit, prior, WRITTEN authorisation from someone with the authority to grant it, covering specific systems, in a specific window, with a defined scope.
- Unauthorised access is a criminal offence under Canada's Criminal Code s.342.1 and s.430(1.1); the United States CFAA, 18 U.S.C. §1030; EU Directive 2013/40/EU; and Spain's Ley Orgánica 10/1995. Quebec Law 25, PIPEDA and the GDPR may also apply to personal information you encounter. If you are unsure whether an action is authorised, it is not.

Disclaimer and Conditions of Use — 3 of 3

6. ETHICS, AI USE AND ACADEMIC INTEGRITY

- Report findings only to parties entitled to receive them; never exfiltrate, retain or publish data encountered during authorised work; respect confidentiality after an engagement ends. Hacking back is prohibited in this course and unlawful in Canada regardless of provocation.
- AI assistance is permitted only under the rule stated in Lesson 1 — the model drafts, the analyst verifies and decides, and every submission declares the tool, the model and what was verified. Undeclared AI-generated work is an academic-integrity matter under the College's Academic Integrity Cheating & Plagiarism Procedure and Policy No. 7 (IPESA). Never submit client data, credentials, keys, log extracts or configuration files to a hosted AI service.

7. LIMITATION OF LIABILITY

- To the fullest extent permitted by law, Cyber.SoHo Educational Hub, its author and contributors are not liable for any direct, indirect, incidental, special, consequential or punitive damages, or loss of data, profit, revenue, business or reputation, arising from use of or reliance on this material or any linked resource. By using it you accept sole responsibility for your actions and their consequences.

8. ACCURACY, CORRECTIONS AND SEVERABILITY

- Report errors through the course forum. Where this notice conflicts with the official course outline, College policy or applicable law, those prevail. If any provision is unenforceable, the remainder continues in force.

You are ready for Lab 01.

Run the three scripts tonight. Watch the two videos. Read the lab brief before Tuesday, not on Tuesday.

Over the next eight weeks you will configure firewalls, harden hosts, deploy sensors and manage keys.

But the reason any of it works is that somebody wrote down what they did, and somebody else could check it.

That is the whole job.

Class 2 — Tuesday 1 September 2026 · Zoning concepts · Quiz 01 · Lab 01 due